

Vulnerability Assessment Report

INTERNAL DEVELOPMENT ENVIRONMENT

V Mouli | 12-04-2026 | Security Audit Project

ASSESSMENT OBJECTIVE

This audit was conducted to identify security misconfigurations in a local development environment using passive, non-intrusive reconnaissance.

AUDIT TOOLKIT

Nmap (Service Discovery), Browser DevTools (Header Analysis), OWASP ZAP (Passive Proxy).

HIGH-LEVEL SUMMARY

Key Vulnerabilities were identified ranging from Medium to Low risk. The environment is currently susceptible to information disclosure and clickjacking due to missing security headers.

FINDING 1 - EXPOSED SERVICES (NMAP)

- **Header:** Finding 01: Exposed Development Port
- **Risk Level:** Low
- **Issue:** Port 8080 is open and running a Vite development server.
- **Impact:** Development servers often lack the security hardening of production servers, potentially leaking source code.
- **Remediation:** Close Port 8080 when not in use or restrict access to specific IP addresses.
- **Evidence:**

```
C:\Users\mouli>nmap -sV -Pn 192.168.231.1 -p 8080
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-11 21:21 +0530
Nmap scan report for 192.168.231.1
Host is up (0.0010s latency).
```

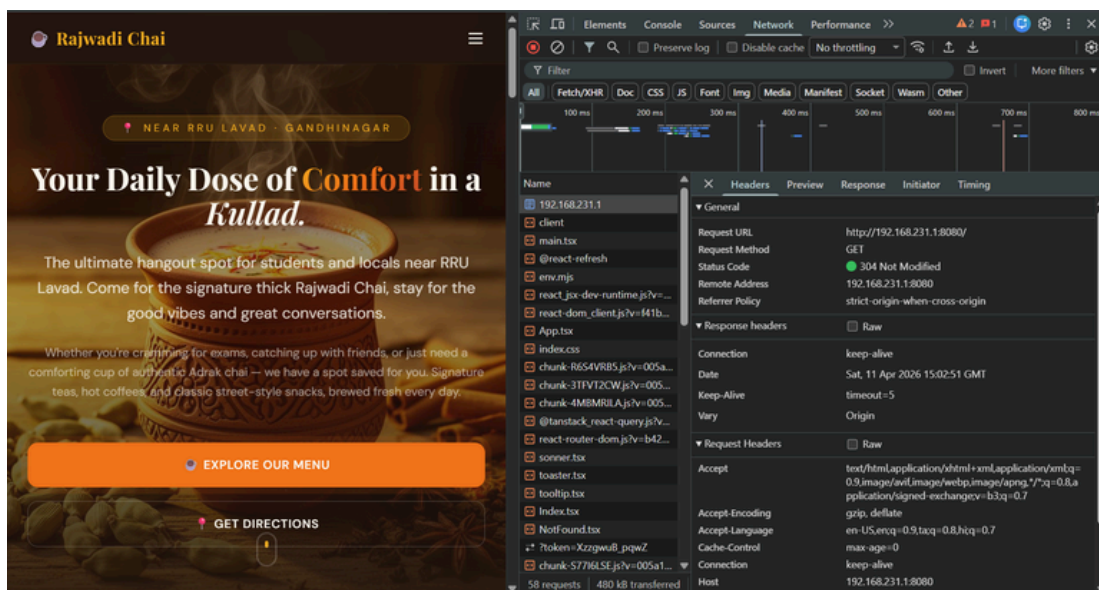
PORT	STATE	SERVICE	VERSION
8080/tcp	open	http-proxy	←

EXPERT INSIGHT

"Defense in Depth": In a secure environment, we assume the first line of defense will eventually fail. Closing unused ports like 8080 is a critical part of Hardening, ensuring that even if an attacker gets onto the local Wi-Fi, they find as few "open doors" as possible.

FINDING 2 – MISSING HEADERS (DEVTOOLS)

- **Header:** Finding 02: Missing Security Headers (HSTS)
- **Risk Level:** Medium
- **Issue:** The server does not send Strict-Transport-Security (HSTS) or X-Frame-Options headers.
- **Impact:** This leaves users vulnerable to Man-in-the-Middle (MITM) attacks and Clickjacking.
- **Remediation:** Configure the web server to include these headers in every HTTP response.
- **Evidence:**



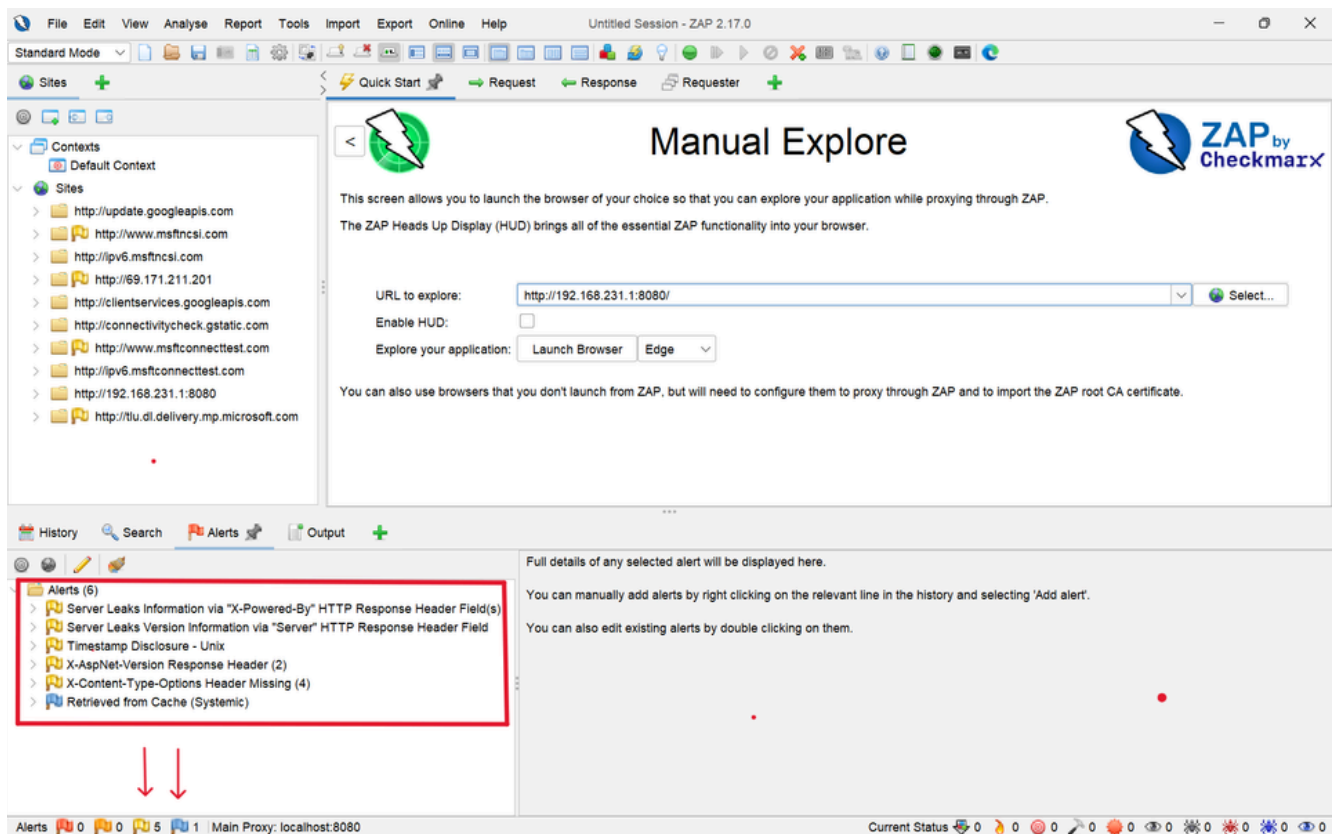
×	Headers	Preview	Response	Initiator	Timing
▼ General					
Request URL		http://192.168.231.1:8080/			
Request Method		GET			
Status Code		304 Not Modified			
Remote Address		192.168.231.1:8080			
Referrer Policy		strict-origin-when-cross-origin			
▼ Response headers		Raw			
Connection		keep-alive			
Date		Sat, 11 Apr 2026 15:02:51 GMT			
Keep-Alive		timeout=5			
Vary		Origin			

EXPERT INSIGHT

Strict-Transport-Security (HSTS) and **X-Frame-Options** are completely absent from this list, successfully identified a security misconfiguration! This is exactly what a missing security header vulnerability looks like in the real world.

FINDING 3 – VERSION DISCLOSURE (ZAP)

- **Header:** Finding 03: Server Version Disclosure
- **Risk Level:** Medium
- **Issue:** The server headers (X-Powered-By) reveal the exact version of the software being used.
- **Impact:** Attackers can use this specific version number to find pre-made "exploit" scripts.
- **Remediation:** Disable "Server Tokens" in the configuration to hide version numbers.
- **Evidence:**



EXPERT INSIGHT

"Never give an attacker a free blueprint." While hiding your technology stack isn't a replacement for patching, broadcasting it via headers drastically reduces the time an adversary needs to weaponize known exploits. By masking this information, you force attackers to guess, generating noisy traffic that gives your defense systems a much better chance of detecting them early.

"Reconnaissance is the most critical phase of a cyber attack." By leaving the X-Powered-By header intact, the application is doing the attacker's homework for them. Stripping these headers forces adversaries to spend exponentially more time and resources profiling the application, increasing the likelihood that they will trigger intrusion detection alarms before a successful breach.